



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Investigate Nightmare Eclipse latest vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Investigate Nightmare Eclipse latest vulnerability - Vulnerability Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

RoguePlanet is a publicly released Microsoft Defender zero-day exploit that the researcher Nightmare Eclipse / Chaotic Eclipse published on 2026-06-09 and that was broadly reported on 2026-06-10. The released proof of concept is best supported as a local privilege-escalation path that abuses a race condition in Microsoft Defender's scan-and-remediation workflow to produce a `SYSTEM` shell on fully patched Windows 10 and Windows 11 systems when exploitation succeeds. No reviewed authoritative source showed that Microsoft had assigned a CVE identifier, published a vendor advisory specifically naming RoguePlanet, or shipped a documented fix mapped to the exact June public PoC as of 2026-06-10.

The most important operational nuance is that RoguePlanet sits on a line between a validated post-foothold local privilege-escalation exploit and a broader vulnerability history that the publisher claims once enabled remote code execution and BitLocker-bypass-adjacent outcomes. The currently published repository, README, and direct source inspection strongly support the LPE assessment. The broader historical claims remain important context, but they should be handled as medium-confidence reporting rather than presented as fully validated current exploit paths.

Public release of full exploit source materially changes defender urgency. Organizations should assume that red teams, criminal operators, and opportunistic malware authors can now study the published C++ implementation, improve race reliability, and adapt the workflow into alternate payloads. The highest-priority defensive response is therefore to scope exposed Windows endpoints, reduce low-privilege code-execution opportunities, and hunt for suspicious Defender-remediation side effects, mounted-image staging, temp-directory artifacts, and unexpected `SYSTEM` process creation.

Executive Assessment	Judgment
Current exploit form	Public Microsoft Defender zero-day local privilege escalation
Confirmed impact	Low-privilege local execution can become `SYSTEM` when the race succeeds
Highest-confidence exposed systems	Windows 10 and Windows 11 endpoints, per the publisher's README
Server risk	Plausible but not directly validated by the released PoC; publisher claims servers remain vulnerable even though the current ISO-mount-dependent PoC does not work there
Exploitation status	Public PoC available; no reviewed authoritative evidence of RoguePlanet-specific in-the-wild exploitation as of 2026-06-10
Immediate defender priority	Hunt for PoC artifacts and privilege-escalation outcomes while tightening application control and mounted-image exposure

2. Intelligence Requirement

This report addresses the following intelligence requirement: what is RoguePlanet, what does the public record actually support about Microsoft Defender exposure and exploitability, which Windows environments are most at risk, and what should defenders do immediately while there is no documented vendor fix tied to the public June 2026 disclosure?

Question	Assessment
What is RoguePlanet?	A publicly released Microsoft Defender zero-day PoC that can achieve `SYSTEM` privileges by racing Defender's own scan/remediation path.
Is the currently released exploit local or remote?	The published June PoC is best supported as local privilege escalation. Historical researcher commentary claims earlier RCE-capable variants existed, but those paths should not be conflated

	with the currently released code.
Which systems are directly confirmed by the publisher?	Windows 10 and Windows 11 with June 2026 patches installed, per the README in the published repository.
Are servers affected?	The README asserts Windows Server installations are also vulnerable, but the released PoC does not currently work there because standard users cannot mount an ISO image. Treat this as a researcher claim rather than independently validated fact.
Is there a CVE or Microsoft fix for RoguePlanet itself?	No reviewed source showed a CVE assignment or documented Microsoft patch specifically mapped to RoguePlanet as of 2026-06-10.
What matters most to defenders?	Assume post-foothold attackers can weaponize the public code, prioritize hosts where low-privilege code execution is plausible, and collect telemetry around Defender remediations, mounted images, temp-path artifacts, and unexpected `SYSTEM` process launches.

3. Source Review and Confidence

Source	Contribution	Confidence
RoguePlanet GitHub README	Publisher-stated exploitation conditions, tested operating systems, and outcome (`SYSTEM` shell).	High
RoguePlanet GitHub repository metadata and commit history	Confirms publication timing and that full source plus a compiled binary were publicly posted on 2026-06-09.	High
Local inspection of `RoguePlanet.cpp` from the published repository	Provides the strongest technical evidence for the June PoC's mechanics: mounted-image handling, Defender scan APIs, temp/junction artifacts, named pipe usage, and `CreateProcessAsUser` / `conhost.exe` execution path.	High
Nightmare Eclipse blog post: `RoguePlanet, a quick history`	Primary-source narrative on earlier RCE and BitLocker-bypass-oriented variants and on the claimed mid-May `mpengine! SysIO*` hardening.	Medium
Help Net Security (2026-06-10)	Corroborates immediate post-Patch-Tuesday disclosure, identifies the issue as a Defender race-condition exploit, and notes external researchers validated LPE behavior.	Medium
The Hacker News (2026-06-10)	Corroborates that the public PoC targets a Defender zero-day race condition and can spawn a `SYSTEM` shell when successful.	Medium
BleepingComputer result snippet (2026-06-10)	Corroborates the researcher's claim that RoguePlanet began as an SMB-based RCE path before being reworked into the	Medium

	currently public form.	
Help Net Security (2026-05-21) on `CVE-2026-41091` / `CVE-2026-45498`	Provides relevant context that earlier Nightmare Eclipse-linked Defender disclosures were later acknowledged and patched by Microsoft.	Medium
CISA KEV JSON feed snapshot	Negative-evidence check only: no RoguePlanet entry or mapped CVE was visible in the reviewed KEV feed on 2026-06-10.	Medium

Overall confidence is high that a real Microsoft Defender LPE proof of concept was published and that it abuses Defender's own privileged handling path to produce a `SYSTEM`-level outcome. Confidence is lower on claims that the same underlying flaw still supports current remote code execution or BitLocker bypass, because those points rely mainly on the researcher's retrospective narrative rather than on the exact June public PoC or on a Microsoft advisory. Accordingly, this report treats the LPE mechanics as high-confidence current risk and the broader historical claims as medium-confidence context.

4.1 Vulnerability Metadata

Field	Value
Public name	`RoguePlanet`
Vendor / component	Microsoft Defender / Microsoft Defender antimalware scan and remediation workflow
Classification used in this report	Microsoft Defender zero-day local privilege escalation
Weakness class	Race condition with file / remediation path redirection behavior in Defender handling, based on the published PoC and researcher statements
CVE	No reviewed CVE assignment as of `2026-06-10`
Severity	Operationally `High` because successful exploitation yields `SYSTEM` and the PoC is public
Attack vector	Local in the currently released PoC
Privileges required	Standard user / low-privilege local execution context
User interaction	Required to the extent that an attacker must first obtain local execution or coerce a user into running a payload; historical pre-hardening RCE claims involve additional victim actions around SMB / `.vhd(x)` access
Public PoC availability	Yes; the public repository contains `RoguePlanet.cpp`, `RoguePlanet.exe`, `README.md`, and screenshot evidence
Observed outcome	`SYSTEM` shell / `SYSTEM` console when the race succeeds
Directly publisher-tested platforms	Windows 10 and Windows 11 with June 2026 patch installed
Server status	Publisher claims Windows Server is vulnerable but says the released PoC does not currently work there because standard users cannot mount ISO images
Exploitation status at review time	Public PoC available; no reviewed authoritative source confirmed

4.2 Technical Mechanics Supported by the Published PoC

Direct inspection of `RoguePlanet.cpp` supports the following high-confidence findings about the released exploit:

- The code dynamically loads Defender's `MpClient.dll`, opens the Defender management interface with `MpManagerOpen`, and triggers a targeted scan via `MpScanStart` against a crafted file resource path.
- The exploit creates a temporary working directory under `%TEMP%\RP\_{GUID}` and repeatedly manipulates paths involving `wormgr.exe`, which becomes the file object the PoC places, deletes, locks, and re-targets during the race.
- The workflow mounts an ISO image, writes or reuses EICAR-like content, and manipulates junctions / reparse points, shadow-copy paths, and directory-change notifications to influence where Defender remediation lands.
- The code uses the named pipe `\\.\pipe\RoguePlanet` and a `CreateProcessAsUser(..., L"C:\Windows\System32\conhost.exe", ...)` execution path so that successful exploitation under `LOCAL SYSTEM` spawns an interactive console in the initiating user's session.
- The README explicitly states the exploit is reliability-sensitive and "hit or miss," although the author claims some hosts achieved 100% success and suggests the race can likely be redesigned for greater reliability.

The central operational implication is that Defender's own privileged cleanup path appears to become the attacker-controlled privilege boundary. This is materially more serious than a product crash or denial-of-service condition because it converts a defensive control into the mechanism that elevates attacker privileges.

4.3 Analyst Findings and Exposure Implications

Finding	Why It Matters
RoguePlanet should be treated first as a post-foothold privilege-escalation issue.	An attacker only needs low-privilege local execution to attempt escalation to `SYSTEM`.
The public exploit code materially increases copycat risk.	Attackers can study and fork working C++ exploit logic instead of starting from patch-diff analysis or blind research.
Hosts can appear fully patched yet still be exposed.	The README explicitly claims Windows 10 and 11 systems with June 2026 patches installed remain exploitable.
The vulnerability family may be broader than the current PoC.	The researcher's historical blog references earlier SMB-hosted `.vhd(x)` coercion and BitLocker-bypass-adjacent behavior, which should shape monitoring even if not treated as validated present-tense behavior.
Server exposure should remain on watchlists.	The public PoC limitation on Windows Server appears tied to ISO mounting constraints, not necessarily to the absence of the underlying vulnerability class.

4.4 MITRE ATT&CK Context

Tactic	Technique	Relevance
Privilege Escalation	`T1068` Exploitation for Privilege Escalation	Direct fit for the released PoC, which turns low-privilege code execution into `SYSTEM`.
Defense Evasion / Privilege Escalation	`T1574` Hijack Execution Flow	Partial contextual relevance because the PoC manipulates file and path-redirection behavior, but the evidence supports a vulnerability-race framing more strongly than a pure hijack-flow mapping.
Execution / Initial Access (historical claim)	`T1204` User Execution	Relevant only to the researcher's historical

only)		coercion narrative around opening malicious `.vhd(x)` content; not assigned as a primary technique for the currently released PoC.
-------	--	--

5. Threat Context

RoguePlanet sits inside a broader 2026 disclosure dispute in which Nightmare Eclipse publicly released multiple Microsoft and Microsoft Defender zero-days. That context matters because it shows both sustained researcher pressure and a pattern in which some initially controversial Defender disclosures were later acknowledged and patched. Help Net Security's 2026-05-21 reporting documented active exploitation and vendor acknowledgement for `CVE-2026-41091` and `CVE-2026-45498`, which public reporting associated with earlier Nightmare Eclipse-linked Defender releases. This history means defenders should avoid dismissing RoguePlanet simply because the June public record had not yet converged on a CVE or vendor bulletin.

At the same time, the reviewed evidence supports careful wording. The current public repository, README, and source code strongly support a local privilege-escalation assessment. The researcher's blog adds important historical claims that RoguePlanet originally supported remote code execution by tricking a victim into opening a malicious `.vhd(x)` from a remote SMB server and that a mid-May Defender change in `mpengine!SysIO\*` reduced or broke those older paths. Those claims are plausible and useful for watchlisting, but they do not carry the same evidentiary weight as the exact June PoC.

Threat Scenario	Assessment
Standard-user foothold on a workstation	Highest-confidence attack path: phishing, commodity malware, or user execution provides a low-privilege foothold; RoguePlanet then escalates to `SYSTEM`.
Shared workstation or VDI abuse	High operational risk because successful `SYSTEM` escalation on a multi-user host can enable cross-user access, credential theft, and durable persistence.
Historical SMB / `.vhd(x)` coercion	Medium-confidence context based primarily on the researcher's historical account; useful for hunt shaping but not strong enough to present as the currently validated exploit chain.
Server-adaptation scenario	Plausible future adaptation risk because the current server limitation appears to be an artifact of the released PoC's ISO-mount dependency rather than proof of server immunity.

The bottom line is that RoguePlanet should be treated as a real post-foothold escalation risk today and as a possible sign of a wider Defender vulnerability family that may continue to evolve in public. Negative evidence such as the absence of KEV mapping or a Microsoft advisory on 2026-06-10 should be treated as time-bounded reporting state, not as assurance.

6.1 Detection Coverage Summary

Signal	Telemetry Source	Analytic Goal	Coverage Confidence
Creation of `%TEMP%\RP_*` working directories and unusual `wermgr.exe` copies below temp paths	MDE `DeviceFileEvents`, Sysmon Event ID 11, EDR file telemetry	Surface direct PoC use or derivative tools that preserve the public artifact pattern.	High for unmodified public PoC
Non-admin user activity immediately followed by `SYSTEM` execution of `conhost.exe`, `cmd.exe`, or similar console processes	MDE `DeviceProcessEvents`, Security 4688, Sysmon Event ID 1	Detect likely successful privilege-escalation outcomes.	Medium to High

Image-mount activity (`.iso`, `.vhd`, `.vhdx`) preceding suspicious temp-path file operations	EDR process/file telemetry, shell or explorer logs	Catch exploitation staging consistent with the published PoC and the researcher's historical descriptions.	Medium
Defender scan or remediation behavior around crafted files named `wormgr.exe` in temp or mounted-media paths	Defender operational logs, forensic timelines, EDR file telemetry	Identify the exploit's Defender-abuse pivot point.	Medium
Junction / reparse-point manipulation in attacker-writable temp directories shortly before privileged file activity	Sysmon / EDR filesystem metadata events where available	Catch the race-and-redirection component of the attack chain.	Medium

Analyst caveat: the public PoC's exact filenames and staging flow can change quickly once other actors fork or refactor the code. Use the rules below as starter analytics for the released June implementation, then tune toward behavior chains rather than only static strings.

6.2 Example Sigma Logic

```

title: Possible RoguePlanet-Style Temp Artifact and SYSTEM Console Escalation
id: 9e83f7ab-bf67-4c5f-b8e9-rogueplanet-lpe
status: experimental
description: Hunts for public RoguePlanet PoC-style temp artifacts and suspicious SYSTEM console execution shortly after user-writable temp activity.
logsource:
  product: windows
  category: process_creation
detection:
  selection_system_console:
    User|contains: 'SYSTEM'
    Image|endswith:
      - '\\conhost.exe'
      - '\\cmd.exe'
      - '\\powershell.exe'
  selection_parent_temp:
    InitiatingProcessCommandLine|contains:
      - '\\AppData\\Local\\Temp\\RP_'
      - 'RoguePlanet'
  condition: selection_system_console and selection_parent_temp
falsepositives:
  - lab validation using the public PoC
  - legitimate administrative tooling executed from a temp path during incident response or malware analysis
level: high

```

6.3 Example KQL Detections and Hunts

```

// RoguePlanet temp-artifact hunt
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has '\\AppData\\Local\\Temp\\RP_' or (FileName =~ 'wormgr.exe' and FolderPath has '\\Temp\\')
| project Timestamp, DeviceName, ActionType, FileName, FolderPath, InitiatingProcessFileName, InitiatingProcessCommandLine, SHA1
| order by Timestamp desc

// RoguePlanet SYSTEM follow-on hunt
DeviceProcessEvents
| where Timestamp > ago(30d)
| where AccountName =~ 'SYSTEM'
| where FileName in~ ('conhost.exe', 'cmd.exe', 'powershell.exe', 'pwsh.exe')
| join kind=leftouter (

```

```

DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ('RoguePlanet', '\\AppData\\Local\\Temp\\RP_', '.iso', '.vhd',
'.vhdx')
| project DeviceId, PreTimestamp=Timestamp, PreFileName=FileName, PreCommand=ProcessCommandLine
) on DeviceId
| where isnull(PreTimestamp) == false and Timestamp between (PreTimestamp .. PreTimestamp + 15m)
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine, PreTimestamp, PreFileName, PreCommand
| order by Timestamp desc

// Mounted image and remote-share context
DeviceFileEvents
| where Timestamp > ago(30d)
| where FileName endswith '.iso' or FileName endswith '.vhd' or FileName endswith '.vhdx' or FolderPath
startswith '\\\\'
| project Timestamp, DeviceName, ActionType, FileName, FolderPath, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by Timestamp desc

```

6.4 Hunt Hypotheses

- If RoguePlanet or a close derivative has been tested in the environment, there will be unusual temp-directory structures, mounted-image activity, and file-redirection artifacts preceding a `SYSTEM` console spawn.
- If an attacker adapted the exploit beyond the public filename set, the more durable signal will be a short interval between low-privilege user execution, mounted-media interaction, and unexpected `SYSTEM` child processes on the same host.
- If historical SMB / `.vhd(x)` coercion variants are being explored, the environment may show suspicious remote-share access and mounted-image events before privileged Defender-side file handling anomalies.

7. Recommendations

Priority	Owner	Recommendation	Defensive Outcome
Critical	Windows Platform / Endpoint Engineering	Identify Windows 10 and 11 hosts where standard users can execute untrusted code and prioritize hardening there first.	Reduces attacker access to the exploit's required foothold.
Critical	SOC / Detection Engineering	Deploy hunts for `%TEMP%\RP_*`, temp-path `wormgr.exe`, mounted-image activity, and unexpected `SYSTEM` console creation.	Improves likelihood of catching public-PoC use or rapid derivative testing.
High	Endpoint Security	Tighten WDAC, AppLocker, or equivalent application-control policies on high-value Windows hosts.	Reduces opportunities for low-privilege payload execution and post-exploitation tool launch.
High	Endpoint Security / IT Operations	Restrict or closely monitor non-admin ISO and VHD mounting where business requirements allow.	Raises attacker cost for the released exploit chain and can remove a key staging dependency.
High	Incident Response	Review recent investigations and retained telemetry for suspicious Defender cleanup behavior, mounted-image artifacts, or unexplained low-privilege-to-`SYSTEM` transitions since 2026-06-09.	Supports retrospective compromise assessment.

High	Vulnerability Management / Threat Intel	Monitor Microsoft Defender engine/platform updates, MSRC, and public reporting for CVE assignment, silent hardening, or vendor guidance tied to RoguePlanet.	Prevents stale mitigation assumptions and supports rapid report updates.
Medium	Server / Workspace Owners	Do not assume Windows Server immunity solely because the public PoC depends on ISO mounting. Keep server fleets in scoping and watch for alternate staging methods.	Reduces false confidence and improves visibility into future exploit adaptations.

Additional analyst guidance:

- Treat RoguePlanet as a real post-foothold escalation risk even if the estate reports as fully patched at the operating-system level.
- Avoid overstating the historical RCE and BitLocker-bypass claims as if they were fully validated current exploit paths; use them to shape monitoring, watchlisting, and vendor-follow-up instead.
- If Microsoft later publishes a CVE, advisory, or silent Defender engine fix that maps to RoguePlanet, reconcile affected-version, mitigation, and detection guidance immediately because the exposure picture may change quickly.

8. References

- 1. RoguePlanet GitHub repository: <https://github.com/MSNightmare/RoguePlanet>
- 2. RoguePlanet raw README: <https://raw.githubusercontent.com/MSNightmare/RoguePlanet/main/README.md>
- 3. RoguePlanet GitHub API repository metadata: <https://api.github.com/repos/MSNightmare/RoguePlanet>
- 4. RoguePlanet GitHub API commit history: https://api.github.com/repos/MSNightmare/RoguePlanet/commits?per_page=3
- 5. Nightmare Eclipse blog post, `RoguePlanet, a quick history`: <https://deadeclipse666.blogspot.com/2026/06/rogueplanet-quick-history.html>
- 6. Help Net Security, `Record Microsoft Patch Tuesday, fresh zero-day`: <https://www.helpnetsecurity.com/2026/06/10/microsoft-patch-tuesday-rogueplanet/>
- 7. The Hacker News, `Microsoft Defender RoguePlanet Zero-Day Grants SYSTEM Access on Updated Windows`: <https://thehackernews.com/2026/06/microsoft-defender-rogueplanet-zero-day.html>
- 8. Help Net Security, `Microsoft Defender vulnerabilities exploited in the wild (CVE-2026-41091, CVE-2026-45498)`: <https://www.helpnetsecurity.com/2026/05/21/microsoft-defender-vulnerabilities-cve-2026-41091-cve-2026-45498/>
- 9. CISA Known Exploited Vulnerabilities catalog JSON feed: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json